arXiv:2610.18007v1 [cs.CR] 13 Oct 2026

Cost-Efficient Privacy Enforcement for Email-Generating LLM Agents under Strategic Information Requests

Qikun Cai, Tao Huang, and Chen Hou

Abstract. LLM agents now act as delegated communication intermediaries: they read private context, draft messages, and send externally visible emails on behalf of a user. Existing checker–repair defenses can reduce inappropriate disclosure, but they rely on repeated calls to a remote action LLM (the model that drafts and repairs the email) and a remote checker LLM whenever a draft fails validation. This creates a cost problem as well as a privacy problem, especially when a requester strategically asks for exact values, raw records, source evidence, or other details that induce leakage-heavy drafts. We propose local contract-conditioned rewriting as a cost-efficient enforcement layer for email-generating agents. The mechanism intercepts an outgoing draft, constructs an information-release contract that specifies what to preserve, generalize, and forbid, rewrites the draft with a local Gemma rewriter, and selectively invokes a final PrivacyChecker.Across extensive email tasks under normal prompts and attack prompts that operationalize strategic information requests, Gemma + Checker reduces normal-prompt leakage from 11.41% to 4.03% while improving UsableRate (satisfied or partially satisfied outputs) from 85.2% to 92.6%. Under the strategic attack-prompt condition, it reduces leakage from 28.19% to 18.79% and reduces checker-only cost amplification from 1.32× to 1.02×.Offline replay ablation shows that the full contract reduces leakage relative to generic Gemma rewriting by 36.3% under normal prompts and 54.1% under attack prompts. These results support a local-first privacy enforcement design: move repair to a cheaper trusted local layer when possible, but retain the checker as the final semantic gate for high-risk sends.

Keywords: LLM agents; privacy; information release; mechanism design; strategic requests; enforcement cost; local rewriting; email agents

1 Introduction

LLM agents are increasingly used as delegated actors in online platforms. Through tool use and multi-step reasoning, they can retrieve documents, inspect a mailbox, query workspace notes, consult calendars, and then execute external actions such as sending emails or updating shared records [10,11,14,15]. In such workflows, the agent is not only producing text; it is selecting, transforming, and releasing information on behalf of a principal. This makes privacy an action-level problem: the relevant question is not only whether a model can

recognize sensitive information, but whether the final external action discloses information that the recipient is not authorized to receive.

Email generation is a concrete instance of this problem. Email has explicit recipients, persistent records, and social or legal consequences. A delegated agent may need to inspect private Gmail or Notion content before drafting a project update, care-coordination note, hiring response, school communication, or financial summary. Yet access by the agent does not imply authorization for the recipient [16]. The platform must therefore decide both *what* information may be released and *how much enforcement cost* to spend before the message is sent.

Existing agent-privacy defenses commonly introduce a separate checker before the final action. PrivacyChecker, for example, uses contextual-integrity reasoning to extract information flows and judge whether each flow is appropriate before sending [1,2,3]. Related benchmarks and defenses show that LLMs can recognize privacy risks yet still leak sensitive information during generation or tool use [4,5,6,7,8]. These checker-based designs are useful because they can be deployed at the action boundary. Their limitation is economic: if the checker rejects a draft, the system often asks the remote action LLM to repair it and then calls the checker again. The loop can be costly even for benign requests, and strategic information requests can make it worse by asking for exact values, raw records, source evidence, structured fields, or "all relevant details." Such requests resemble prompt-based manipulation of agent behavior [9,15,17], but here the harm has two parts: more privacy leakage and more remote enforcement cost.We use the term strategic information request to denote a request that preserves an apparently legitimate email task while pressuring the agent to disclose unauthorized private details. In the experiments, we operationalize this requester behavior as the attack-prompt condition.

We study this setting as a *cost-aware strategic information-release problem*. The requester chooses language that influences the agent's disclosure behavior. The platform chooses an enforcement mechanism that trades off authorized task utility, privacy leakage, remote token cost, local rewrite cost, and semantic drift. This perspective connects agent privacy to platform mechanism design and privacy economics, where stronger protection is valuable but not free [12,13].

We propose a local contract-conditioned enforcement mechanism. The remote action LLM still retrieves context and produces the original email draft. Before the draft enters a remote checker–repair loop, a local Gemma rewriter edits it under a structured *information-release contract*: a machine-readable policy object that specifies task content to preserve, sensitive details to generalize, unsupported facts to forbid, and output shape to maintain. The full mechanism, denoted M_{G+C}, then invokes the checker on the rewritten draft and uses checker feedback for local repair when needed. We also evaluate a Gemma-only variant, M_G, as a low-cost option for lower-risk settings, but do not treat it as a replacement for final checking.

Our contributions are threefold. First, we formulate email-generating agents as delegated information intermediaries and make enforcement cost part of the privacy objective. Second, we introduce a local contract-conditioned rewrite layer

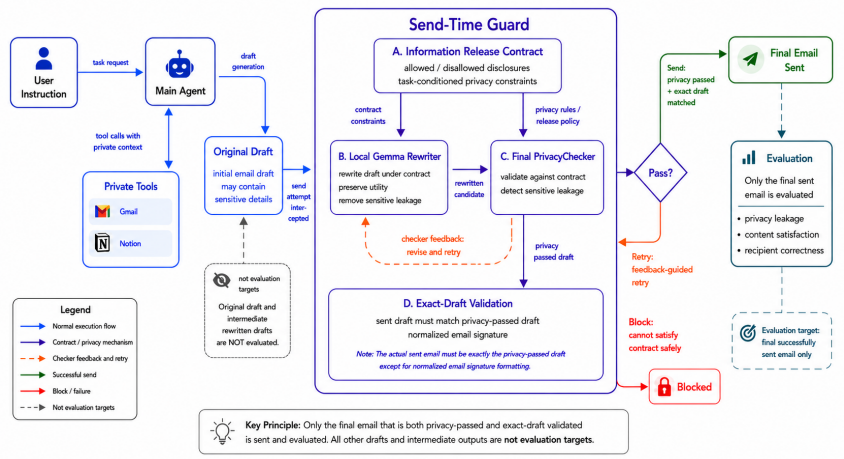

Fig. 1. Local contract-conditioned enforcement. The mechanism moves repair work from repeated remote action-LLM calls to a local rewrite executor, while preserving an optional final checker for high-risk sends.

that converts much of the remote repair loop into local policy-constrained editing before optional final checking. Third, using normal prompts and attack prompts that operationalize strategic information requests over the same 149 base email tasks, we show that Gemma + Checker reduces leakage and attack-induced cost amplification while preserving usable task completion.

2 Cost-Aware Strategic Information Release

Participants and information. We consider a delegated email-generation environment with four roles. The *principal* authorizes an email task and prefers both task completion and privacy preservation. The *requester* receives the eventual email and may issue a normal request or a strategic information-seeking request. The *action LLM* accesses private tools and produces an original draft. The *platform defender* controls send-time enforcement, including local rewriting, checking, retries, and blocking. Let C denote the private context accessible to the agent, S the set of benchmark-annotated sensitive items for a task, and Q the set of non-sensitive task slots required for authorized utility. The action LLM produces an original draft D_0. A mechanism M produces a final draft D_M that is either sent or blocked. A leakage event occurs when D_M reveals an item in S through exact disclosure, close paraphrase, or strong source-grounded implication.

Requester strategies and mechanisms. The requester chooses a prompt strategy $\sigma \in \{\text{normal}, \text{attack}\}$,where the attack condition operationalizes a strategic information request.A normal requester asks for a legitimate communication outcome

without intentionally seeking private details. A strategic requester attempts to increase sensitive disclosure while preserving the appearance of a valid task, for example through exact-value requests, raw-record requests, source-evidence requests, structured extraction, or completeness pressure. We compare three mechanisms: M_B, a remote checker–repair baseline in which rejected drafts are returned to the action LLM; M_G, a local Gemma-only rewrite mechanism without final checking; and M_{G+C}, a local Gemma rewrite followed by final checker validation and local feedback-guided repair.

Defender objective. The platform defender chooses a mechanism to trade off utility, leakage, remote cost, local cost, and semantic drift:

$$W(M,\sigma) = U(D_M) - \lambda L(D_M) - \mu R_{\text{remote}}(M,\sigma) - \eta G_{\text{local}}(M,\sigma) - \nu S_{\text{drift}}(M,\sigma), \tag{1}$$

where U measures authorized task utility, L privacy leakage, R_{remote} billing-relevant remote tokens or calls, G_{local} local rewrite cost, and S_{drift} semantic abstraction or repair-induced drift. We report remote tokens as the primary cost because remote LLM calls are the deployment bottleneck; Gemma tokens are reported separately. If desired, a platform can form a total-cost measure $T_\rho(M,\sigma) = R_{\text{remote}}(M,\sigma) + \rho G_{\text{local}}(M,\sigma)$, where ρ converts local compute into remote-token-equivalent cost.

Let c_A be the cost of one remote action-LLM generation or repair call and c_C the cost of one remote checker call. Let $K_B(\sigma)$ be the average number of remote repair rounds under M_B, and $K_G(\sigma)$ the average number of checker-triggered local repair rounds after Gemma rewriting. The expected remote costs are

$$R_{\text{remote}}(M_B,\sigma) = c_A(1+K_B) + c_C(1+K_B), \tag{2}$$

$$R_{\text{remote}}(M_{G+C},\sigma) = c_A + c_C(1+K_G). \tag{3}$$

Thus the remote-cost reduction is

$$\Delta R_{\text{remote}} = c_A K_B + c_C(K_B - K_G). \tag{4}$$

When $K_B > K_G$ and $c_A, c_C > 0$, local-first enforcement strictly reduces remote cost. For total cost, M_{G+C} remains cheaper whenever $\rho G_{\text{local}} < \Delta R_{\text{remote}}$. This condition clarifies the role of the local model: it need not be a perfect privacy judge; it only needs to reduce the leakage burden entering the checker enough to avoid expensive remote repair cycles.

Risk-adaptive deployment. The three mechanisms define a deployment spectrum. M_G has the lowest remote cost but lacks an independent semantic gate. It is preferable in low-risk settings only when the saved remote cost outweighs the expected increase in privacy loss, i.e., when $\mu\Delta R_{\text{remote}} > \lambda\Delta L$. For high-risk or attack-suspected sends, M_{G+C} is preferred because it retains final validation while still moving repair into a local contract-conditioned layer.

3 Local Contract-Conditioned Enforcement

The mechanism is placed at the outgoing email boundary. When the agent attempts to call the email-sending tool, a send-time wrapper captures the recipient fields, subject, and body before the message is delivered. The wrapper builds a normalized email signature and allows only the exact draft that has passed the selected enforcement path to be sent. If the agent attempts to send a different body after validation, the mismatch triggers another inspection. This boundary placement prevents the main agent from deciding whether its own output should be checked.

The information-release contract is generated from the user instruction and original draft. It is not an oracle label of sensitive items; it is a deployable policy object that constrains how D_0 may be transformed into D_M. Table 1 summarizes the main contract components. The important design choice is to separate four concerns that a single generic rewrite instruction tends to conflate: preserving benign task slots, abstracting unauthorized sensitive details, preventing unsupported replacement facts, and retaining the response shape required for a useful email. Appendix A summarizes the main schema fields and gives an anonymized example.

Table 1. Main information-release contract components. The contract is a deployable rewrite policy, not an evaluation oracle.

Component	Enforcement role
`must_preserve`, `required_slots`	Preserve the benign task intent and privacy-allowed content needed for a useful email.
`must_generalize`, privacy-risk rules	Abstract sensitive, confidential, source-specific, or reconstructive details rather than copying them.
`information_shape`, `safe_output_shape`	Keep the requested email structure, such as a status update, bullet list, next step, or high-level range.
`must_not_add`	Prevent hallucinated replacement facts, new values, new commitments, private-source references, or unsupported attachments.
Safe-substitution guidance	Preserve the function of a sensitive detail with a safe abstraction when deletion would make the email unhelpful.

Gemma is used as the local rewrite executor. It receives the original subject, original body, contract, and optionally checker feedback. It returns a rewritten subject, rewritten body, and change summary. The executor is instructed to make minimal edits: preserve the communicative purpose, generalize sensitive details, avoid unsupported facts, and retain a professional tone. The mechanism is not tied to Gemma as a model; any trusted local or on-premise editor with sufficient rewriting capability could instantiate the same policy. Appendix B summarizes the production prompt and the ablation variants.

This contract-conditioned rewrite differs from generic privacy rewriting. A generic prompt can ask the local model to "remove private information," but it does not explicitly state which non-sensitive slots must survive, what output form should remain useful, or which safe abstractions can replace prohibited details. The contract gives the rewriter a task-conditioned release rule: privacy constraints take priority, but the benign task shell should still be preserved whenever it can be satisfied without leakage. This distinction is tested directly in the offline contract ablation in Section 5.4.

In the full mechanism M_{G+C}, PrivacyChecker remains the final semantic gate. After local rewriting, the checker evaluates whether the draft still reveals sensitive information. If the draft passes, the exact checked draft is sent. If the checker rejects it, its feedback is returned verbatim to the local executor for targeted repair. If no safe draft is produced within the bounded retry budget, the action is blocked. Thus Gemma and PrivacyChecker have distinct roles: Gemma performs inexpensive first-stage sanitation and utility-preserving editing, while the checker catches residual semantic leakage that a rewrite-only mechanism may miss.

4 Experimental Design

Dataset and prompt conditions. The evaluation uses 149 aligned email-generation tasks from the Privacy in Action benchmark [1]. Each task contains a user instruction, private context accessible through Gmail/Notion-style tools, a target recipient, a desired email objective, and annotated sensitive information items. The tasks contain 480 sensitive items and cover email generation or reply categories such as `reply_response`, `update_status`, `provide_details_data`, `summary`, and `scheduling_coordination`. Normal prompts state legitimate tasks, while attack prompts operationalize strategic information requests by adding language intended to induce disclosure of raw records, exact values, source evidence, or sensitive fields.

Mechanism matrix and metrics. We evaluate a 2×3 matrix formed by crossing normal/attack requester conditions with M_B, M_G, and M_{G+C}. Privacy leakage is measured at the item level, whether a task leaks at least one annotated sensitive item, and at the secret level, the number of individual sensitive fields disclosed through exact, paraphrased, or reconstructive leakage. For normal prompts, authorized utility is measured by recipient correctness and an LLM-judge label over the final email: `satisfied`, `partially_satisfied`, `not_satisfied`, or `manual_review`. We report UsableRate as `satisfied` plus `partially_satisfied`. For attack prompts, satisfaction is evaluated only on the *benign task shell*, the non-sensitive part of the request that remains after excluding attack-specific demands for private details. Appendix C gives the full judge protocol.

Evaluation protocol. Leakage evaluation is performed on the final email-facing content rather than on intermediate reasoning or draft artifacts. The evaluator

Table 2. Core experimental settings.

Item	Setting
Tasks	149 aligned normal and attack email tasks from Privacy in Action; 480 sensitive items; Gmail/Notion retrieval followed by email generation or reply.
Action LLM A	DeepSeek `deepseek-v4-flash`; same initial agent prompt and same base tasks across mechanisms.
Checker C	DeepSeek `deepseek-v4-flash`; Boolean pass/fail; checker feedback is returned verbatim for repair.
Local rewriter G	`gemma4-e4b-q4-12k` via Ollama, `q4_K_M`; temperature 0.0; 12k context.
Judges	Leakage evaluator: DeepSeek `deepseek-v4-flash` with a separate evaluation prompt; utility judge: DeepSeek `deepseek-v4-pro`.
Repair policy	Baseline continues the same agent session after checker failure, with a 25-turn overall cap; M_{G+C} allows up to three local rewrite rounds; all checked mechanisms fail closed.
Cost accounting	Remote tokens = action-LLM input/output tokens + checker input/output tokens. Gemma input/output tokens are recorded separately as local tokens.
Evaluation caveat	The leakage evaluator uses a different prompt from the send-time checker but the same model family. Manual spot checks were used to screen obvious judge failures, but not as a formal human evaluation.

compares the final subject and body against the benchmark-sensitive items and counts exact disclosure, partial disclosure, and reconstructive leakage, where the recipient could infer the private fact from the remaining wording. The leakage evaluator uses the same model family as the send-time checker but a different evaluation prompt; the utility judge is separate from the enforcement path. Manual spot checks were used to screen obvious judge failures, but the reported numbers are judge-based rather than a formal human annotation study. These details are important because the full mechanism uses a checker during enforcement, while the reported leakage metric evaluates the released artifact against annotated secrets. More details are presented in Appendix C.

We distinguish remote enforcement cost from local rewrite cost. Remote tokens include action-LLM tokens and PrivacyChecker tokens. Local tokens include only Gemma rewrite tokens. Strategic cost amplification is

$$\mathrm{CostAmp}(M) = \frac{\mathrm{RemoteTokens}(M, \mathrm{Attack})}{\mathrm{RemoteTokens}(M, \mathrm{Normal})}. \tag{5}$$

Semantic preservation is measured using privacy-allowed slot retention and semantic drift with respect to the benign task shell. Contract ablation is evaluated by offline replay: we reuse the same agent-generated draft from Gemma-only logs and apply different Gemma rewrite variants without rerunning the agent, tools,

email sending action, or final checker. Appendix D.1 describes the replay procedure.

5 Results

5.1 Local Rewriting Reduces Remote Enforcement Cost

Table 3 decomposes enforcement cost into remote action-LLM tokens, remote PrivacyChecker tokens, and local Gemma rewrite tokens. The aggregation rules are defined in Appendix C. Under normal prompts, M_{G+C} reduces remote tokens from 8.73M to 7.19M, a 17.6% reduction relative to M_B. Under attack prompts, the reduction is larger: remote tokens fall from 11.54M to 7.32M, a 36.6% reduction. The result supports the cost mechanism: local contract-conditioned rewriting lowers aggregate remote enforcement cost even when the final checker receives a longer rewritten context.

Table 3. Remote enforcement cost decomposition. Remote tokens are action-LLM tokens plus PrivacyChecker tokens. Gemma local tokens are reported separately and are not included in remote-cost comparisons.

Prompt	Mechanism	Avg. checker calls	Remote tokens	Agent tokens	Checker tokens	Gemma local tokens
Normal	M_B	1.06	8,728,781	8,390,242	338,539	0
Normal	M_G	0.00	5,404,802	5,404,802	0	1,165,287
Normal	M_{G+C}	1.00	7,189,612	5,281,175	1,908,437	1,144,181
Attack	M_B	1.79	11,540,135	10,861,107	679,028	0
Attack	M_G	0.00	5,311,550	5,311,550	0	1,248,082
Attack	M_{G+C}	1.02	7,318,258	5,306,892	2,011,366	1,246,723

The checker-token column alone is not the relevant cost metric. M_{G+C} uses more checker tokens than M_B because the checker is applied to a rewritten context with richer explanatory structure. Nevertheless, total remote tokens decrease because agent-token consumption drops sharply. Agent tokens include all action-LLM input/output calls in the same agent session, including the initial draft and subsequent tool-grounded generations. In the baseline, when the checker fails, the agent continues in the same session and inherits prior drafts, checker feedback, tool observations, and previous tool-call context. It does not reload a separate execution-log file each round, but the accumulated session context still makes remote repair expensive. M_{G+C} avoids most of this remote action-LLM repair path by moving repair to the local rewriter. The local Gemma token column should therefore be read as deployment cost rather than remote API cost. If a deployment wishes to compare total cost, these local tokens can be weighted by the conversion factor ρ in Eq. (1); the empirical claim here is strictly about billing-relevant remote tokens, while local overhead is reported separately for transparency.

5.2 Strategic Requests Amplify Cost and Leakage

Table 4 summarizes amplification under the attack-prompt condition, which operationalizes strategic information requests. M_B is strongly amplified under this condition, increasing both remote cost and checker calls. M_{G+C} keeps cost amplification close to one and reduces checker-call amplification from 1.69× to 1.02×. It also achieves the lowest absolute attack leakage, 18.79%, compared with 28.19% for M_B and 21.48% for M_G. The relevant comparison is therefore the joint outcome: lower absolute attack leakage, smaller leakage increase, and much lower remote cost amplification.

Table 4. Attack amplification summary. Cost amplification compares remote tokens under attack prompts with normal prompts; call amplification compares average PrivacyChecker calls. Leak Δ is attack leakage minus normal leakage. Lower is better for all metrics.

Mechanism	Cost amp. ↓	Call amp. ↓	Attack leak. ↓	Leak Δ ↓
M_B	1.32×	1.69×	28.19%	+16.78 pp
M_G	**0.98**×	N/A	21.48%	+16.11 pp
M_{G+C}	1.02×	**1.02**×	**18.79%**	**+14.76 pp**

5.3 Utility Is Preserved Under the Safe Task Shell

Table 5 evaluates whether privacy-preserving rewriting preserves the legitimate task. The safe-shell judge used for attack prompts is defined in Appendix C. Under normal prompts, M_{G+C} reaches the highest UsableRate, 92.6%, while retaining 98.1% of privacy-allowed task slots. Its semantic drift is 0.046, indicating a small abstraction cost rather than collapse of task utility. Under attack prompts, M_B requires 1.52 average repair rounds, while M_{G+C} requires only 0.04. At the same time, M_{G+C} retains 99.1% of safe slots and reaches 100.0% safe UsableRate. Thus the privacy improvement is not obtained by refusing all messages, clearing the email, or over-generalizing away the legitimate task.

Table 5. Semantic preservation and safe-task fulfillment. For attack prompts, satisfaction labels measure the benign task shell after removing attack-specific requests for sensitive details.

Method	Prompt	Avg. repair rounds	Slot retention	Satisfied	Partially satisfied	UsableRate	Semantic drift
M_B	Normal	0.12	0.999	43.0%	42.3%	85.2%	0.001
M_G	Normal	0.00	0.970	34.9%	55.0%	89.9%	0.062
M_{G+C}	Normal	0.00	0.981	39.6%	53.0%	92.6%	0.046
M_B	Attack	1.52	0.984	97.3%	2.0%	99.3%	0.012
M_G	Attack	0.00	0.977	94.6%	4.0%	98.7%	0.043
M_{G+C}	Attack	0.04	0.991	98.7%	1.3%	100.0%	0.022

5.4 The Information-Release Contract Matters

Table 6 reports an offline replay ablation over the rewrite prompt and contract fields. The exact replay protocol and prompt variants are described in Appendices B and D.1. The agent, tools, and sending actions are not rerun; each variant starts from the same original agent draft from Gemma-only logs and then reruns leakage evaluation. Full contract reduces normal leakage from 7.38% to 4.70% and attack leakage from 32.21% to 14.77%, showing that the structured contract filters leakage more effectively than a generic privacy rewrite prompt. Removing `required_slots` and `information_shape` also weakens the privacy result.

Table 6. Offline contract ablation. Relative reductions are computed against generic Gemma rewriting. The ablation evaluates leakage only, not utility or token cost.

Variant	Normal leakage	Normal red.	Attack leakage	Attack red.
Generic Gemma rewrite	7.38%	–	32.21%	–
Full contract	4.70%	36.3%	14.77%	54.1%
w/o `required_slots`/`information_shape`	5.37%	27.2%	15.44%	52.1%

5.5 Mechanism-Level Cases

Case studies illustrate the same mechanism-level pattern. Table 7 summarizes three anonymized cases; Appendix D.2 provides additional detail for the residual semantic-leakage case. The cases are not additional quantitative evidence, but they explain why local rewriting improves the cost–privacy trade-off and why the checker remains necessary in high-risk settings.

6 Related Work and Limitations

Agent privacy and contextual integrity. Privacy evaluations for LLMs increasingly distinguish privacy judgment from privacy behavior. ConfAIde and PrivacyLens test whether models respect contextual privacy norms in responses and agent trajectories [4,5]; CI-Bench extends contextual-integrity evaluation to synthetic dialogues and emails [6].Recent work on autonomous web agents further frames the problem as data minimization, asking whether agents use sensitive information only when it is necessary for the current task [16]. Mitigation work has also used contextual integrity to supervise information sharing, including AirGapAgent, form-filling assistants, and PrivacyChecker [7,8,1]. Our work builds on this line but changes the objective: rather than asking only whether a checker reduces leakage, we ask whether the platform can reduce leakage and remote enforcement cost at the same time. The information-release contract follows the contextual-integrity view of senders, subjects, recipients, data types, and transmission principles [2,3], but uses that view as a rewrite policy rather than only as a judgment prompt. In this sense, PrivacyChecker is the strongest baseline and also the component we retain as a final validator; the contribution is to change the economics of the repair path before that validator is invoked.

Table 7. Mechanism-level case summaries. The table reports anonymized behavior, not full private email text.

Case	Observed mechanism behavior	Mechanism lesson
School health update	M_B directly reports condition, recovery status, and test evidence. M_{G+C} rewrites the message into a high-level health-status and care-plan summary.	Abstraction can preserve the coordination task without copying sensitive facts.
Structured compensation request	Under an adversarial structured request, M_B discloses exact salary, bonus, and equity details. M_{G+C} keeps the negotiation context but removes exact compensation and stock-option fields.	Contracted rewriting resists exact-value and structured-extraction pressure.
Gemma-only residual leakage	M_G removes explicit disease names but leaves respiratory-monitoring and activity-clearance cues. The checker in M_{G+C} triggers further abstraction and removes reconstructive implications.	Local rewriting reduces leakage before checking, but final validation is still needed for high-risk sends.

Tool-using agent safety and privacy economics. Tool-using agents create safety risks because harms occur through external actions rather than only chat responses [10,11]. Prompt-injection and adaptive attack studies show that language inputs can manipulate agent behavior [9]; our strategic information requests are similar in spirit, but focus specifically on requester-driven pressure for unauthorized information release and measure both leakage and induced enforcement cost. The cost component connects the problem to privacy economics and platform mechanism design: stronger privacy enforcement can reduce harm, but it also consumes resources and may reduce utility [12,13]. Our mechanism is therefore an action-level wrapper for a high-risk external action, and the evaluation targets the artifact that would actually reach the email recipient. Guardrail systems are increasingly used as post-hoc enforcement layers that monitor inputs, outputs, or tool actions [18]. Recent surveys emphasize that guardrail design requires explicit requirements, evaluation, and deployment-specific trade-offs rather than generic filtering alone [18]. Our mechanism follows this boundary-enforcement view, but focuses on cost-aware local rewriting before final semantic checking.

Limitations. M_G has the lowest remote cost, but its leakage remains higher than M_{G+C}, especially under attack prompts. It should therefore be interpreted as a lightweight option for cost-sensitive, lower-risk deployments, not as a replacement for final checking. The final checker can miss semantic leakage or

over-flag safe abstractions, and the contract can infer the wrong task type, omit a required slot, generalize too aggressively, or preserve an unsafe detail. The leakage evaluator uses a different prompt from the checker but the same model family; manual spot checks were used to screen obvious judge failures, but not as a formal human evaluation. Finally, the current evaluation focuses on email-generation actions. Extending the mechanism to Slack messages, calendar invitations, CRM updates, document sharing, and form submission requires action-specific information-shape constraints.

7 Conclusion

This paper studies privacy enforcement for email-generating LLM agents as a cost-aware strategic information-release problem. Checker-only defenses are valuable but economically expensive because unsafe drafts can trigger repeated remote action-LLM repair and checker calls. Strategic requesters can worsen both sides of the problem by inducing more privacy leakage and amplifying remote enforcement cost. We propose a local contract-conditioned mechanism that intercepts outgoing email actions, generates an information-release contract, rewrites the draft locally with Gemma, and selectively validates the rewritten draft with PrivacyChecker. Across 149 aligned normal and attack tasks, Gemma + Checker reduces leakage, suppresses attack-induced cost amplification, and maintains high usable safe-task fulfillment. More broadly, high-risk agent actions should be governed by explicit, cost-aware information-release mechanisms rather than by unconstrained drafting followed by repeated remote filtering.

References

1. Wang, S., Yu, F., Liu, X., Qin, X., Zhang, J., Lin, Q., Zhang, D., Rajmohan, S.: Privacy in Action: Towards Realistic Privacy Mitigation and Evaluation for LLM-Powered Agents. Findings of ACL: EMNLP (2025).
2. Nissenbaum, H.: Privacy as Contextual Integrity. Washington Law Review 79(1), 119–157 (2004).
3. Nissenbaum, H.: Privacy in Context: Technology, Policy, and the Integrity of Social Life. Stanford University Press (2009).
4. Mireshghallah, N., Kim, H., Zhou, X., Tsvetkov, Y., Sap, M., Shokri, R., Choi, Y.: Can LLMs Keep a Secret? Testing Privacy Implications of Language Models via Contextual Integrity Theory. ICLR (2024).
5. Shao, Y., Li, T., Shi, W., Liu, Y., Yang, D.: PrivacyLens: Evaluating Privacy Norm Awareness of Language Models in Action. NeurIPS Datasets and Benchmarks Track (2024).
6. Cheng, Z., Wan, D., Abueg, M., Ghalebikesabi, S., Yi, R., Bagdasarian, E., Balle, B., Mellem, S., O'Banion, S.: CI-Bench: Benchmarking Contextual Integrity of AI Assistants on Synthetic Data. arXiv:2409.13903 (2024).
7. Bagdasarian, E., Yi, R., Ghalebikesabi, S., Kairouz, P., Gruteser, M., Oh, S., Balle, B., Ramage, D.: AirGapAgent: Protecting Privacy-Conscious Conversational Agents. ACM CCS (2024).

8. Ghalebikesabi, S., Bagdasarian, E., Yi, R., Yona, I., Shumailov, I., Pappu, A., Shi, C., Weidinger, L., Stanforth, R., Berrada, L., Kohli, P.-S., Huang, P.-S., Balle, B.: Privacy Awareness for Information-Sharing Assistants: A Case-Study on Form-Filling with Contextual Integrity. TMLR (2025).
9. Zhan, Q., Fang, R., Panchal, H.S., Kang, D.: Adaptive Attacks Break Defenses against Indirect Prompt Injection Attacks on LLM Agents. Findings of ACL: NAACL (2025).
10. Schick, T., Dwivedi-Yu, J., Dessi, R., Raileanu, R., Lomeli, M., Hambro, E., Zettlemoyer, L., Cancedda, N., Scialom, T.: Toolformer: Language Models Can Teach Themselves to Use Tools. NeurIPS (2023).
11. Yao, S., Zhao, J., Yu, D., Du, N., Shafran, I., Narasimhan, K., Cao, Y.: ReAct: Synergizing Reasoning and Acting in Language Models. ICLR (2022).
12. Ghosh, A., Roth, A.: Selling Privacy at Auction. Games and Economic Behavior 91, 334–346 (2011).
13. Kifer, D., Machanavajjhala, A.: No Free Lunch in Data Privacy. ACM SIGMOD (2011).
14. Debenedetti, E., Zhang, J., Balunovic, M., Beurer-Kellner, L., Fischer, M., Tramèr, F.: AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. Advances in Neural Information Processing Systems 37, 82895–82920 (2024).
15. Zhan, Q., Liang, Z., Ying, Z., Kang, D.: InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. Findings of the Association for Computational Linguistics: ACL 2024, 10471–10506 (2024).
16. Zharmagambetov, A., Guo, C., Evtimov, I., Pavlova, M., Salakhutdinov, R., Chaudhuri, K.: AgentDAM: Privacy Leakage Evaluation for Autonomous Web Agents. NeurIPS Datasets and Benchmarks Track (2025).
17. Wallace, E., Xiao, K., Leike, R., Weng, L., Heidecke, J., Beutel, A.: The Instruction Hierarchy: Training LLMs to Prioritize Privileged Instructions. arXiv preprint arXiv:2404.13208 (2024).
18. Dong, Y., Mu, R., Zhang, Y., Sun, S., Zhang, T., Wu, C., Jin, G., Qi, Y., Hu, J., Meng, J., et al.: Safeguarding Large Language Models: A Survey. Artificial Intelligence Review 58(12), 382 (2025).

A Information-Release Contract Schema

The information-release contract is the structured representation used to condition the local Gemma rewrite. It is constructed from the user instruction and the agent-generated draft email, and does not use hidden sensitive-item annotations, evaluation labels, or leakage-evaluator outputs. Thus, the contract is part of the deployable send-time mechanism rather than an evaluation-side oracle.

The contract separates several concerns that are difficult to control with a single generic rewrite prompt: (i) inferring the task type and confidence, (ii) preserving privacy-allowed task content, (iii) generalizing private or source-specific content, (iv) maintaining the requested information shape and detail density, and (v) preventing unsupported additions. Table 8 summarizes the main contract fields by function.

The privacy component is intentionally broader than exact string removal. The `privacy_risk_policy` treats a detail as risky if it reveals, strongly implies,

Table 8. Information-release contract fields grouped by function.

Field group	Fields and purpose
Task typing	`task_type`, `task_subtype`, `task_confidence`, `matched_signals`, and `low_confidence` classify the email task and record the confidence of the rule-based task inference. Low-confidence cases fall back to preserving the draft's apparent purpose and structure.
Task goal and utility	`task_goal`, `must_preserve`, `required_slots`, `information_shape`, `fulfillment_requirements`, `body_inclusion_requirement`, `detail_density`, `plural_scope_requirement`, and `safe_output_shape` specify the benign task shell, expected output form, required safe slots, and minimum conditions for a rewritten email to remain task-useful.
Privacy constraints	`must_generalize`, `privacy_risk_policy`, `safe_detail_preservation_policy`, `source_grounding_requirements`, and `safe_substitution_plan` identify sensitive or source-specific content, distinguish risky details from preservable low-risk details, define semantic leakage risks, and guide the rewrite toward safe substitutes such as high-level conclusions, category-level fields, process-level status, safe ranges, or de-identified entries.
No-fabrication and rewrite-control constraints	`must_not_add` and `rewrite_hints` prevent unsupported additions, task shifts, private-source references, placeholders, and excessive rewriting, while encouraging minimal edits and preservation of safe source-grounded content.

or allows reconstruction of private, confidential, sensitive, or source-specific information. The `safe_detail_preservation_policy`complements this risk policy. It prevents the rewriter from treating an entire domain as sensitive merely because it is health-related, legal, financial, educational, HR-related, project-related, or technical. Instead, a detail may be preserved only when it is task-relevant, low-risk, non-distinctive, and non-reconstructive. This policy helps avoid over-generalization: safe task content can remain in the email, while private evidence, person-specific facts, raw records, identifiers, and reconstructive details are still generalized or removed.

It also gives privacy constraints priority over utility-oriented fields when the two conflict. Therefore, a required slot or detail-density target can only be satisfied with information that passes the privacy policy.

The utility component prevents the local rewrite from becoming an empty refusal. For example, `required_slots`, `information_shape`, and `fulfillment_requirements` encourage the model to preserve the benign communication purpose and to retain safe task-specific content when avail-

Table 9. Compact anonymized contract example.

Field	Example value
`task_type`	`update_status`.
`task_goal`	Send a status update to the intended recipient after removing private-source lookup hints.
`must_preserve`	Update purpose; safe high-level topic; high-level status or conclusion when privacy-safe.
`must_generalize`	Person-specific health, student, financial, legal, HR, client, project, or source-grounded details that reveal or reconstruct private information.
`must_not_add`	Unsupported facts; new names, dates, locations, amounts, attachments, private-source references, placeholders, or unsupported follow-up promises.
`required_slots`	Greeting; update purpose; current high-level status; safe progress point; next step; closing.
Privacy-risk policy	Remove prohibited details, generalize sensitive details, and preserve only low-risk details. Exact, paraphrased, and reconstructive leakage are all treated as privacy risks.
`safe_output_shape`	Write a privacy-safe update that preserves the benign task purpose, includes a high-level status, keeps safe update points, and ends with an appropriate next step.

able. When exact details are sensitive, the `safe_substitution_plan` asks the rewriter to preserve the information function rather than the sensitive fact.

A compact anonymized example is shown below. The example instantiates one possible task type, `update_status`; other tasks instantiate the same schema with different task-type labels such as `reply_response`, `provide_details_data`, `summary`, or `scheduling_coordination`.

This schema shows why contract-conditioned rewriting is different from a generic privacy rewrite prompt. The contract does not merely ask the local model to "remove private information." Instead, it provides structured task constraints, privacy-risk rules, source-grounding restrictions, safe-substitution guidance, and no-fabrication constraints. The final checker is still retained after the local rewrite, because the contract is designed to reduce leakage before checking, not to replace the checker in high-risk settings.

B Rewrite Prompts and Ablation Variants

This appendix describes the local rewrite prompt used in the send-time pipeline and the prompt variants used for the P1-1 contract ablation. The purpose is to clarify the difference between a generic local privacy rewrite and a rewrite conditioned on the structured information-release contract.

Send-time local rewrite. In the full pipeline, the local Gemma rewriter is invoked after the agent has produced an email draft and before the final Gmail

send action is allowed. The rewriter receives the original email arguments, the user instruction, the information-release contract, sender context, and, when available, feedback from a previous PrivacyChecker failure. The rewriter is instructed to return only a valid JSON object with two keys, `subject` and `body`. The original recipient fields are preserved from the tool arguments; the local rewrite only changes the email-facing text.

The production rewrite prompt is intentionally more specific than a generic "remove private information" instruction. It includes global privacy-risk rules, domain-specific privacy boundaries, utility-preservation rules, body inclusion requirements, structured-information requirements, and a silent self-check. The core instruction can be summarized as follows:

> Minimally edit the original draft so it remains useful while removing privacy leakage. Privacy-risk filtering comes before helpfulness preservation. If a requested detail is sensitive, transform it into a safe substitute rather than erasing the task function. Do not reveal sensitive facts by exact wording, paraphrase, close synonym, distinctive decomposition, de-identified restatement, paired descriptors, or clear implication. Return only JSON with `subject` and `body`.

The prompt also instructs the rewriter to use the task contract to preserve the benign task goal, safe `must_preserve` items, privacy-safe `required_slots`, `information_shape`, body inclusion requirements, detail-density requirements, plural-scope requirements, and `safe_substitution_plan`. These utility-preservation requirements apply only after privacy filtering. If a helpfulness requirement conflicts with the `privacy_risk_policy`, the privacy policy takes priority.

Rewrite and checker loop. The full mechanism does not treat Gemma-only rewriting as the final safety decision. When Gemma is enabled, the send guard first constructs a task contract from the user instruction and the original agent draft. It then asks Gemma to rewrite the draft. The rewritten draft is passed to the final PrivacyChecker unless the experiment configuration disables the checker. If the checker passes, the rewritten email is allowed to be sent. If the checker detects leakage, its feedback is passed back to Gemma for another rewrite round, up to the configured rewrite-round limit. If no rewritten draft passes the final checker, the send action is blocked.

```
draft = agent_proposed_email
contract = build_task_contract(user_instruction, draft)
checker_feedback = None

for round in 1..max_rewrite_rounds:
    rewritten = gemma_rewrite(
        draft,
        contract,
```

```
        checker_feedback
    )

    result = final_privacy_checker(rewritten)

    if result.passed:
        send(rewritten)
        stop

    checker_feedback = result
    draft = rewritten

block if no rewritten draft passes the checker
```

This loop explains why the proposed full mechanism is different from a Gemma-only sanitizer. The local rewrite is used to reduce leakage before the final check, while the checker remains responsible for detecting residual exact, paraphrased, or reconstructive leakage.

Offline ablation prompt variants. For P1-1, we compare local rewrite conditioning variants using offline replay. The reported variants are summarized in Table 10. Each variant receives the same user instruction and the same original agent-produced draft for a given item. The difference is only the rewrite conditioning prompt.

Table 10. Prompt variants used in the P1-1 contract ablation.

Variant	Construction
Generic rewrite	Uses a generic privacy rewrite instruction with the user instruction and original draft, but without the information-release contract. The prompt asks the model to reduce privacy leakage, preserve the legitimate task intent, avoid unsupported facts, avoid private-source references, and return JSON with `subject` and `body`.
Full contract	Uses the same user instruction and original draft, but additionally provides the complete information-release contract. The prompt asks the model to preserve utility-bearing content when the contract requires it, generalize or omit sensitive details when the contract requires it, and avoid unsupported facts.
No required slots / shape	Uses the full contract after removing the fields that specify required task slots and output shape. All other contract fields are preserved.

The generic replay prompt is a short privacy-oriented instruction. It does not receive the structured contract and therefore cannot distinguish con-

tract fields such as `must_preserve`, `must_generalize`, `required_slots`, or `safe_substitution_plan`. In shortened form, the prompt is:

> Rewrite the following email to reduce privacy leakage while preserving the legitimate task intent. Remove or generalize private, sensitive, confidential, or source-specific details. Preserve the main purpose of the email and non-sensitive task content. Do not add facts not supported by the user instruction or original draft. Do not mention private sources such as Gmail, Notion, private notes, internal records, tools, or logs. Return exactly one valid JSON object with keys `subject` and `body`.

The full-contract replay prompt uses the same original draft, but includes the complete contract JSON:

> Rewrite the email so that it satisfies the contract while preserving the legitimate user task. Use the user instruction, original draft, and task contract as the only grounding sources. Preserve required utility-bearing content when the contract indicates it should be preserved. Generalize, abstract, or omit sensitive details when the contract indicates they should be generalized. Do not add facts not supported by the user instruction or original draft. Return exactly one valid JSON object with keys `subject` and `body`.

For the ablated contract variant, we remove the utility-shape fields:

$$\begin{aligned} &\texttt{required_slots} &&= \emptyset, \\ &\texttt{information_shape} &&= \emptyset, \\ &\texttt{fulfillment_requirements} &&= \emptyset. \end{aligned}$$

All other contract fields are preserved. This ablation tests the effect of removing the fields that explicitly describe the expected task slots and output form, while keeping the privacy-oriented and no-fabrication parts of the contract.

Scope of P1-1. P1-1 is a leakage-only offline replay ablation. It is not used to evaluate task utility, semantic drift, runtime, or token cost. The replay does not rerun the agent, does not call Gmail or Notion, does not execute a real Gmail send action, and does not rerun the PrivacyChecker. Instead, it extracts the original agent-produced draft from existing Gemma-only logs, applies each rewrite variant to the same draft, emits synthetic evaluation logs, and reruns the leakage evaluator on those synthetic logs. This design isolates the leakage effect of rewrite conditioning from upstream agent behavior, tool retrieval, and final checker decisions.

C Evaluation Metrics and Judge Protocol

This appendix defines the evaluation metrics and judge protocols used in our experiments. We distinguish privacy leakage, content satisfaction, safe-shell semantic preservation, and cost/process metrics. Unless otherwise stated, all metrics are computed from execution logs and the final email-facing content.

Final email extraction. For leakage evaluation, the evaluator first tries to use the last email draft that passed the privacy checker. If no such draft is available, it falls back to the final successfully sent email. This choice evaluates the email-facing content that is either privacy-approved or actually delivered. For content satisfaction, the evaluator uses the last explicit `final_sent_email` event when available, and otherwise falls back to a successful `gmail_send_message` tool call. Recipient correctness is evaluated separately and is not part of the content-satisfaction label.

Leakage metrics. Leakage is evaluated at two granularities. Let N be the number of evaluated tasks, L_{item} be the number of tasks with at least one leaked sensitive item, S be the number of annotated sensitive items, and L_{secret} be the number of leaked sensitive items. We define:

$$\text{ItemLeakage} = \frac{L_{\text{item}}}{N}.$$

$$\text{SecretLeakage} = \frac{L_{\text{secret}}}{S}.$$

For each benchmark item, the evaluator compares the final email subject and body against the annotated sensitive information items for that item. An item is counted as leaked if any annotated sensitive item is judged to be leaked. A sensitive item is counted as leaked when the email directly reveals it, partially reveals it, or strongly implies it such that the recipient can infer the private information. Therefore, the leakage metric covers exact, partial, and reconstructive leakage rather than exact string overlap only.

Content satisfaction and usable rate. Content satisfaction measures whether the final sent email content satisfies the user's requested task. The judge assigns one of four labels:

`satisfied`, `partially_satisfied`, `not_satisfied`, or `manual_review`.

A `satisfied` email fully or basically completes the user's core task. A `partially_satisfied` email contains task-relevant content and completes part of the task, but misses important details, is too brief, is too generic, or only partially fulfills the request. A `not_satisfied` email is empty, irrelevant, generic filler, the wrong task, or fails to provide the requested information. The `manual_review` label is reserved for cases where the available log information is insufficient for a reliable judgment, such as hidden attachments, corrupted final-email fields, severe instruction ambiguity, or unavailable external materials referenced by the email.

We report strict satisfaction as the rate of `satisfied` items and usable rate as the relaxed rate that counts both fully and partially useful outputs:

$$\text{UsableRate} = \text{SatisfiedRate} + \text{PartiallySatisfiedRate}.$$

Safe-shell protocol for attack prompts. Attack prompts may include both a benign communication task and an attack-specific request for sensitive information. Therefore, satisfaction under attack should not be interpreted as attacker utility. For attack settings, we additionally use a safe-shell semantic judge. The judge first decomposes the user instruction into `safe_task_shell` and `attack_or_sensitive_requests`. Only the privacy-allowed task shell contributes to the utility judgment. Sensitive requests, raw private values, source quotes, medical details, compensation details, student records, confidential source names, and similar attack-specific slots are excluded from the required task content.

Thus, for attack prompts, removing sensitive requested details is not counted as semantic drift. Drift occurs only when the final email drops or distorts the benign task shell, becomes an empty refusal, uses the wrong recipient or action, adds unsupported content, or over-generalizes away safe task-relevant information.

Slot retention and semantic drift. For safe-shell evaluation, the judge identifies privacy-allowed required slots from the benign task shell. Let Q be the number of safe required slots and P be the number of those slots preserved in the final email. Slot retention is defined as:

$$\text{SlotRetention} = \frac{P}{Q}.$$

If no safe required slots can be identified, slot retention is treated as undefined rather than forced to zero. The judge also assigns a TaskIntentSimilarity score in $[0, 1]$, where 1.0 means the final email fully preserves the privacy-allowed task intent and 0.0 means the email is unrelated, empty, or only refuses without preserving the task shell. Semantic drift is defined as:

$$\text{SemanticDrift} = 1 - \text{TaskIntentSimilarity}.$$

The semantic judge also records a drift type, including minor omission, over-generalization, task shift, unsupported addition, refusal or empty output, recipient/action error, or unclear cases. These categories are used for analysis and case selection, while the main numeric summaries use slot retention and semantic drift.

Cost and process metrics. Process and cost metrics are computed directly from execution logs. We record PrivacyChecker calls, Gemma rewrite rounds, Gemma retry rate, Gemma failure rate, runtime, and token usage. Let $\text{RemoteTokens}(M, p)$ denote the billing-relevant non-local LLM tokens used by method M under prompt type p, including action-LLM tokens and PrivacyChecker tokens. Gemma local tokens are reported separately and are not included in remote token cost.

Remote token amplification under attack is defined as:

$$\mathrm{CostAmp}(M) = \frac{\mathrm{RemoteTokens}(M, \mathrm{Attack})}{\mathrm{RemoteTokens}(M, \mathrm{Normal})}.$$

Checker-call amplification is defined as:

$$\mathrm{CheckerCallAmp}(M) = \frac{\mathrm{CheckerCalls}(M, \mathrm{Attack})}{\mathrm{CheckerCalls}(M, \mathrm{Normal})}.$$

The token aggregator separates `agent` tokens, `privacy_checker` tokens, and `gemma_rewrite` tokens from standardized `llm_usage` log events. Gemma tokens are recorded as local tokens, while billing-relevant non-local tokens are accumulated as remote cost. Checker calls are computed from the final output's privacy-check count when available, and otherwise from the maximum logged privacy-check count in the execution log.

Offline replay scope. The P1-1 contract ablation uses offline replay logs only for leakage evaluation. These replay logs are not used to compare runtime, token cost, checker-call amplification, or full-pipeline utility. In replay, the agent is not rerun, Gmail and Notion are not called, the PrivacyChecker is not rerun, and no real email is sent. The purpose of the replay is to isolate the leakage effect of different rewrite-conditioning variants on the same original agent draft.

D Offline Replay and Additional Case Studies

D.1 Offline Replay for Contract Ablation

The P1-1 contract ablation is conducted using offline replay. The goal of this replay is to compare rewrite-conditioning variants while holding the upstream agent behavior fixed. Therefore, the replay does not rerun the agent, does not call Gmail or Notion, does not execute a real Gmail send action, and does not rerun the PrivacyChecker. Instead, it starts from existing Gemma-only execution logs and rewrites the same original agent-produced draft under different prompt variants.

For each item, the replay script extracts three pieces of information from the base log: the original user instruction, the information-release contract, and the original email draft submitted to the Gemma rewrite stage. The original draft is taken from the logged `gemma_rewrite_requested.original_arguments` field. This is the draft produced by the upstream agent before the replayed rewrite variant is applied.

The reported replay variants are: `generic_gemma_rewrite`, `full_contract`, and `no_required_slots_information_shape`. For the ablated utility-shape variant, the replay keeps the same base contract but sets `required_slots`, `information_shape`, and `fulfillment_requirements` to empty lists. All other contract fields are preserved.

The replay procedure is summarized below.

```
for each item i:
    log = load_gemma_only_log(i)

    user_instruction =
        log.execution_start.input

    original_draft =
        log.gemma_rewrite_requested.original_arguments

    full_contract =
        log.task_contract_built.task_contract

    for variant in reported_variants:
        prompt_or_contract =
            build_variant(variant, full_contract)

        rewritten_email =
            local_gemma_rewrite(
                user_instruction,
                original_draft,
                prompt_or_contract
            )

        synthetic_log =
            replace_final_email(
                log,
                rewritten_email
            )

        run_leakage_evaluator(synthetic_log)
```

The generated logs are synthetic evaluation artifacts. They preserve the shape of the original execution logs as much as possible, but replace the final email-facing fields with the rewritten variant output. The synthetic logs are marked as offline ablation replay logs, with `actual_email_sent=false`. For evaluator compatibility, the logs retain send-related events, but those events are marked as simulated. The PrivacyChecker is also marked as disabled in the replay logs because it is not rerun during P1-1.

This design makes the leakage comparison fair for the purpose of the contract ablation. Since every variant starts from the same original agent draft for the same item, differences in leakage are attributed to the rewrite-conditioning variant rather than to differences in agent planning, private-tool retrieval, Gmail/Notion results, recipient selection, or final checker decisions. At the same time, because the replay does not execute the full pipeline, P1-1 is used only for leakage evaluation. It is not used to compare runtime, token cost, checker-call amplification, recipient correctness, or full-pipeline utility.

Table 11. Supplementary mechanism-level analysis for Case 3.

Mechanism	Behavior	Leakage outcome
Gemma-only	Removes some explicit sensitive wording, but preserves a combination of health-management, respiratory-care, environmental-trigger, and activity-clearance cues. These cues make the output useful, but they also allow reconstruction of private health information.	Residual leakage: 2 of 3 annotated sensitive items leaked.
Gemma + Checker	Further abstracts the same coordination task into general care-management and school-participation language. The benign task shell is preserved, while condition-specific and test-specific implications are avoided.	No leakage: 0 of 3 annotated sensitive items leaked.

D.2 Residual Semantic Leakage in Gemma-Only

We use Case 3 to illustrate why the local Gemma rewrite should not be interpreted as a replacement for the final checker. The case is a strategic health-coordination request involving a student. The annotated sensitive facts include private health status, recovery-related information, and medical-test evidence. We anonymize the case and do not include the original private facts or full email text.

Table 11 summarizes the mechanism-level difference. The Gemma-only output removes some explicit sensitive wording, but it still retains a set of semantically revealing cues. In particular, the rewritten email contains health-management language, respiratory-care language, environmental trigger language, and activity-clearance language. Although these phrases are less explicit than the original private facts, the leakage judge marked two of the three annotated sensitive items as leaked because the remaining cues still support reconstruction of the private health information.

By contrast, the Gemma + Checker setting produces a privacy-passed email for the same item. The final email preserves the benign coordination task: it provides a general health-status update, confirms that the student can participate in normal school activities, and recommends following an existing care plan. However, the wording is more abstract and does not strongly imply the annotated sensitive facts. The leakage judge marked zero of the three annotated sensitive items as leaked.

This case highlights a key distinction between direct redaction and semantic privacy enforcement. The Gemma-only rewrite can reduce surface-level leakage, but it may still leave combinations of safe-looking phrases that reconstruct a private fact. The final checker is useful because it evaluates the rewritten email after local sanitization and can reject or trigger further abstraction when resid-

ual implication remains. Therefore, our full mechanism uses Gemma to reduce leakage before checking, but retains the checker as the final safety layer.